

International Cybersecurity and Digital Forensics Academy (ICDFA)

Course Code: GRC102 – Information Security Governance

Week 4 Practical Laboratory

Linux Security Monitoring and Auditing

Audit and Control Assurance Report

Student Name: Mercy Ajayi

Registration Number: C11/26/CGRCE/17219

Date of Submission: October 8, 2026

TABLE OF CONTENTS

1. Executive Summary	1
2. Scope and Authorisation.....	1
2.1 Assigned environment and why it changed.....	2
2.2 Environment used	2
2.3 Boundaries.....	3
3. Methodology.....	4
3.1 Troubleshooting log.....	5
4. Findings.....	6
4.1 Module 1 – auditd Configuration and Events	6
4.2 Module 2 – log management and analysis.....	12
4.3 Module 3 – Lynis Security Assessment	17
4.4 Optional Hardening and Retest: Login Banner (BANN-7126)	22
5. Control-Monitoring Table	24
6. SIEM and Continuous Monitoring Mapping	26
7. Governance Discussion and Escalation Questions	28
8. Remediation and Retest Plan.....	29
9. Conclusion	30

1. Executive Summary

I carried out a security monitoring and audit review of one Linux host. I installed and configured auditd, reviewed the systemd journal since auth.log and syslog were not available, ran a Lynis 3.1.6 assessment, and mapped the evidence to control owners, thresholds, and retest steps.

Overall posture. The accountability controls are working. Sudo commands and access to the watched account files were recorded with the user, terminal, and time. However, the host still has some baseline security gaps. Lynis returned a hardening index of 61, with 2 warnings and 49 suggestions. The main areas that need attention are patching, network protection, and log retention.

Top three findings

1. Patch backlog. When Lynis was installed, apt reported 1,452 packages not upgraded. I did not verify how many of these were security updates. Lynis also flagged the absence of an automatic update tool (PKGS-7420).
2. No host firewall. Lynis test FIRE-4590 reported that no firewall or packet filter is configured on the host.
3. Audit coverage and log retention. auditd was not installed by default, so events before 00:23:14 on 07 October are not covered by audit logs. The audit logs are also stored only on the host, which Lynis flagged under LOGG-2154.

There were also two additional observations. The ssh generator crashed twice, although the cause was not confirmed. Also, the broad watch rule on /etc/passwd records many normal reads, which could make it harder to identify actual changes.

One control was remediated during the lab. I added a legal warning banner to /etc/issue, and a targeted Lynis retest confirmed that the check now passes.

2. Scope and Authorisation

2.1 Assigned environment and why it changed

The lab brief identifies the ICDFA Ubuntu Practice Hub as the primary environment. However, when I was ready to carry out the lab, the Hub displayed a message saying it was temporarily paused, and both browser and SSH access were blocked while ICDFA reviewed the Azure policy (Figure 1).

I asked the class representative how I should proceed and was told that I could use my own Kali Linux VM if the academy's Kali and Ubuntu environments were unavailable. I was also advised to take screenshots of my evidence and document any command issues and how I resolved them (Figure 2). I therefore used my personal Kali VM for this lab and followed those instructions.

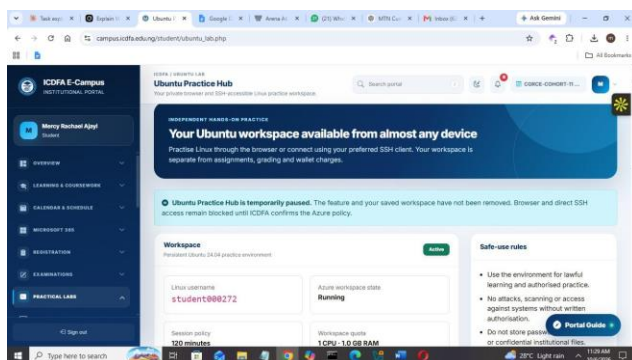


Figure 1: ICDFA Ubuntu Practice Hub temporarily paused

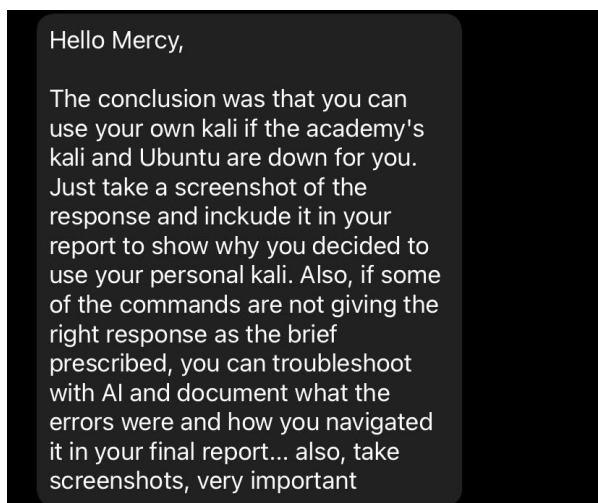


Figure 2: Approval to use a personal Kali VM

2.2 Environment used

- Kali Linux Rolling, version 2026.2, kernel 6.19.14+kali, 64-bit, running in VirtualBox on my computer.
- **Network mode:** NAT, so the VM was behind my own network connection and was not directly exposed to other systems.
- **Account used:** the default kali user with sudo privileges. I installed auditd 4.1.2 and Lynis 3.1.6 from the Kali repositories.
- All timestamps in the evidence are from the VM clock, which was set to EDT, not WAT.

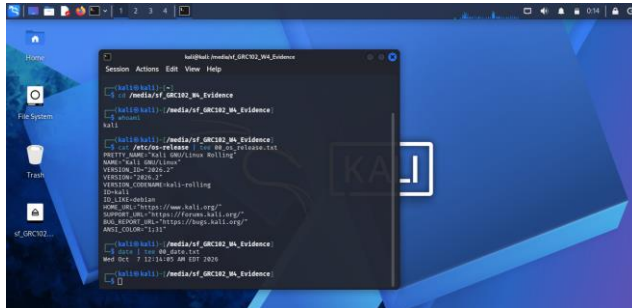


Figure 3: System information and lab start time

2.3 Boundaries

- All activities were carried out on the VM described above. I did not target any external systems, hosts, or accounts.
- I generated only benign test events. For example, I opened `/etc/passwd` in nano and exited without saving. I did not deliberately create failed login attempts.
- The changes made during the lab were limited to installing auditd and Lynis, creating `/etc/audit/rules.d/custom.rules`, and adding two warning lines to `/etc/issue`. I kept a backup of the original file as `/etc/issue.bak`.
- I did not disable logging or delete any evidence.

3. Methodology

- **auditd:** I checked whether the service was available, installed it, created a custom rules file, generated benign test events, and then reviewed the events using `ausearch` and `aureport`.
- **Log analysis:** I used `journalctl` with `grep` to review authentication activity, privilege use, errors, and warnings. Since `/var/log/auth.log` and `/var/log/syslog` were not available on Kali, I used the systemd journal as the main log source.
- **Lynis:** I installed Lynis 3.1.6 from the Kali repository, ran a full system audit, and recorded the hardening index, warnings, and suggestions. I also reviewed `/var/log/lynis-report.dat` for the detailed results.
- **Governance mapping:** I mapped the findings into a control-monitoring table showing the control owner, threshold, remediation action, and retest step.
- **Evidence handling:** I saved command outputs to text files using `tee` and captured screenshots of the relevant results.

3.1 Troubleshooting log

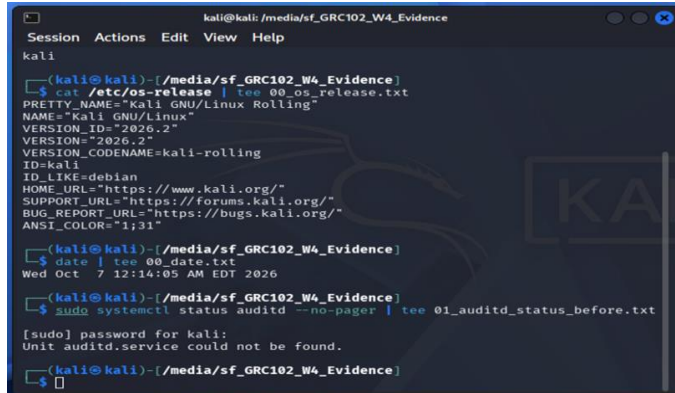
The table below records the main issues I encountered during the lab, what I understood to be the cause, and how I handled each one.

Issue	Cause (as far as known)	What I did	Evidence
ICDFA Ubuntu Hub and academy Kali were unavailable	The Hub was temporarily paused by ICDFA while the Azure policy was being reviewed	Used my personal Kali VM after getting approval from the class representative	Figures 1 & 2
/var/log/auth.log does not exist	Kali uses the systemd journal by default	Did not use the auth.log watch rule and used journalctl as the equivalent log source	Figure 7
auditctl -l showed “No rules” after restarting auditd	The exact cause was not confirmed. The audit log shows that the rules were added at 00:29:43, so the rules may not have finished loading when I first checked	Ran augenrules --load and checked the rules again. All four rules then appeared	Figures 7 & 9
aureport --login returned no events	auditd was installed after my desktop login, and I did not perform another login afterwards	Recorded this as a coverage gap rather than treating it as an error	Figure 15
ausearch -k auth_failures returned no matches	There was no auth_failures rule because /var/log/auth.log was not available	Documented it as expected based on the logging setup	Figure 12
Permission denied when reading /var/log/lynis-report.dat	The file is readable only by root	Reran the command using sudo	No Screenshot taken
ssllh generator crashed	The cause was not confirmed	Ran systemctl daemon-reload to test the issue. The crash did not happen again	Figures 24–26
First VM was too slow and had a password problem	The old VM had resource and credential issues	Deleted the old VM and imported a fresh pre-built Kali image	Not needed

4. Findings

4.1 Module 1 – auditd Configuration and Events

Service status. auditd was not installed on the fresh Kali VM. I installed `auditd` and `audispd-plugins`, then started and enabled the service. I confirmed that the service was active (running) and configured to start automatically.



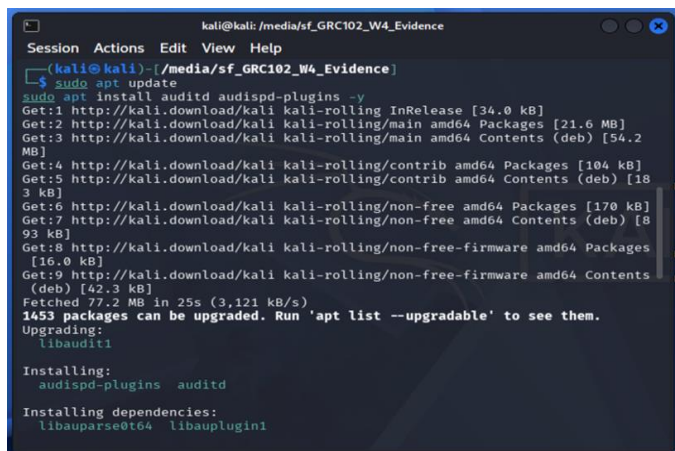
```
kali@kali: /media/sf_GRC102_W4_Evidence
Session Actions Edit View Help
kali
(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$ cat /etc/os-release | tee 00_os_release.txt
PRETTY_NAME="Kali GNU/Linux Rolling"
NAME="Kali GNU/Linux"
VERSION_ID="2026.2"
VERSION="2026.2"
VERSION_CODENAME=kali-rolling
ID=kali
ID_LIKE=debian
HOME_URL="https://www.kali.org/"
SUPPORT_URL="https://forums.kali.org/"
BUG_REPORT_URL="https://bugs.kali.org/"
ANSI_COLOR="1;31"

(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$ date | tee 00_date.txt
Wed Oct 7 12:14:05 AM EDT 2026

(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$ sudo systemctl status auditd --no-pager | tee 01_auditd_status_before.txt
[sudo] password for kali:
Unit auditd.service could not be found.

(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$
```

Figure 4: systemctl status auditd before installation (unit not found)



```
kali@kali: /media/sf_GRC102_W4_Evidence
Session Actions Edit View Help
(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$ sudo apt update
Get:1 http://kali.download/kali kali-rolling InRelease [34.0 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [21.6 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [54.2 MB]
Get:4 http://kali.download/kali kali-rolling/contrib amd64 Packages [104 kB]
Get:5 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb) [18 3 kB]
Get:6 http://kali.download/kali kali-rolling/non-free amd64 Packages [170 kB]
Get:7 http://kali.download/kali kali-rolling/non-free amd64 Contents (deb) [8 93 kB]
Get:8 http://kali.download/kali kali-rolling/non-free-firmware amd64 Packages [16.0 kB]
Get:9 http://kali.download/kali kali-rolling/non-free-firmware amd64 Contents (deb) [42.3 kB]
Fetched 77.2 MB in 25s (3,121 kB/s)
1453 packages can be upgraded. Run 'apt list --upgradable' to see them.
Upgrading:
libaudit1
Installing:
audispd-plugins auditd
Installing dependencies:
libauparse0t64 libauplugin1
```

Figure 5: sudo apt install auditd audispd-plugins; apt reports 1,453 packages can be upgraded

```
kali@kali: /media/sf_GRC102_W4_Evidence
Session Actions Edit View Help

(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$ sudo systemctl start auditd
$ sudo systemctl enable auditd
$ sudo systemctl status auditd --no-pager | tee 02_auditd_status_after.txt
Created symlink /etc/systemd/system/multi-user.target.wants/auditd.service'
→ /usr/lib/systemd/system/auditd.service'.
• auditd.service - Security Audit Logging Service
   Loaded: loaded (/usr/lib/systemd/system/auditd.service; enabled; preset:
disabled)
   Active: active (running) since Wed 2026-10-07 00:23:14 EDT; 553ms ago
  Invocation: 4a8de45a4a74f5289831941f253816a
     Docs: man:auditd(8)
    Main PID: 20641 (auditd)
      Tasks: 2 (limit: 4470)
     Memory: 920K (peak: 2M)
        CPU: 17ms
    CGroup: /system.slice/auditd.service
            └─20641 /usr/sbin/auditd

Oct 07 00:23:14 kali systemd[1]: Starting auditd.service - Security Audit Log
ging Service ...
Oct 07 00:23:14 kali auditd[20641]: No plugins found, not dispatching events
Oct 07 00:23:14 kali auditd[20641]: Init complete, auditd 4.1.2 listening for
events (startup state enable)
Oct 07 00:23:14 kali systemd[1]: Started auditd.service - Security Audit Log
ging Service.
```

Figure 6: systemctl status auditd after installation: active (running), enabled, auditd 4.1.2

Rules: I created a custom rules file with four rules. Two monitor access to `/etc/passwd` and `/etc/shadow`, using the keys `passwd_changes` and `shadow_changes`. The other two monitor `execve` activity for 64-bit and 32-bit programs, using the key `program_execution`. I left out the `auth.log` watch rule because `/var/log/auth.log` does not exist on the Kali VM.

```
kali@kali: /media/sf_GRC102_W4_Evidence
Session Actions Edit View Help

Tasks: 2 (limit: 4470)
Memory: 920K (peak: 2M)
CPU: 17ms
CGroup: /system.slice/auditd.service
        └─20641 /usr/sbin/auditd

Oct 07 00:23:14 kali systemd[1]: Starting auditd.service - Security Audit Log
ging Service ...
Oct 07 00:23:14 kali auditd[20641]: No plugins found, not dispatching events
Oct 07 00:23:14 kali auditd[20641]: Init complete, auditd 4.1.2 listening for
events (startup state enable)
Oct 07 00:23:14 kali systemd[1]: Started auditd.service - Security Audit Log
ging Service.

(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$ ls -l /var/log/auth.log | tee 03_authlog_check.txt
ls: cannot access '/var/log/auth.log': No such file or directory

(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$ sudo nano /etc/audit/rules.d/custom.rules

(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$ sudo systemctl restart auditd
$ sudo auditctl -l | tee /media/sf_GRC102_W4_Evidence/05_loaded_rules.txt
No rules

(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$
```

Figure 7: `ls -l /var/log/auth.log`: No such file or directory; below it, `nano`, `systemctl restart auditd` and `auditctl -l` showing “No rules”

```
kali@kali: /media/sf_GRC102_W4_Evidence
Session Actions Edit View Help

Oct 07 00:23:14 kali auditd[20641]: No plugins found, not dispatching events
Oct 07 00:23:14 kali auditd[20641]: Init complete, auditd 4.1.2 listening for
events (startup state enable)
Oct 07 00:23:14 kali systemd[1]: Started auditd.service - Security Audit Log
ging Service.

(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$ ls -l /var/log/auth.log | tee 03_authlog_check.txt
ls: cannot access '/var/log/auth.log': No such file or directory

(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$ sudo nano /etc/audit/rules.d/custom.rules

(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$ sudo systemctl restart auditd
$ sudo auditctl -l | tee /media/sf_GRC102_W4_Evidence/05_loaded_rules.txt
No rules

(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$ sudo cat /etc/audit/rules.d/custom.rules
-w /etc/passwd -p rwx -k passwd_changes
-w /etc/shadow -p rwx -k shadow_changes
-a always,exit -F arch=b64 -S execve -k program_execution
-a always,exit -F arch=b32 -S execve -k program_execution

(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$
```

Figure 8: Contents of `/etc/audit/rules.d/custom.rules`

```

kali@kali: /media/sf_GRC102_W4_Evidence
Session  Actions  Edit  View  Help
lost 0
backlog 4
backlog_wait_time 60000
backlog_wait_time_actual 0
enabled 1
failure 1
pid 25250
rate_limit 0
backlog_limit 8192
lost 0
backlog 4
backlog_wait_time 60000
backlog_wait_time_actual 0
Old style watch rules are slower
-w /etc/passwd -p rwx -k passwd_changes
-w /etc/shadow -p rwx -k shadow_changes
-a always,exit -F arch=b64 -S execve -F key=program_execution
-a always,exit -F arch=b32 -S execve -F key=program_execution
(kali@kali) - [ /media/sf_GRC102_W4_Evidence ]
$ auditctl -l | tee 05_loaded_rules_clean.txt
-w /etc/passwd -p rwx -k passwd_changes
-w /etc/shadow -p rwx -k shadow_changes
-a always,exit -F arch=b64 -S execve -F key=program_execution
-a always,exit -F arch=b32 -S execve -F key=program_execution
(kali@kali) - [ /media/sf_GRC102_W4_Evidence ]
$

```

Figure 9: `auditctl -l` after `augenrules --load`: four custom rules loaded

Event queried: `sudo nano /etc/passwd`. At **00:37:29–00:37:30**, I opened `/etc/passwd` in nano using sudo and exited without saving. The audit record showed the following:

Field	What the audit record shows
Time	10/07/2026, 00:37:29–00:37:30 (VM clock, EDT)
User (who)	audit=kali. This remained kali even though sudo elevated the process to root.
Privilege	uid=root and euid=root on the nano record, showing that the command ran with elevated privileges through sudo.
Action (what)	proctitle=sudo nano /etc/passwd, followed by nano /etc/passwd, from terminals pts0 and pts1.
File	/etc/passwd, owned by root with mode 644
Access type	The file was opened with O_RDONLY, meaning it was opened for reading. No write-mode open was recorded during this period.
Rule that matched	key=passwd_changes

```

kali@kali: /media/sf_GRC102_W4_Evidence
Session Actions Edit View Help
type=PROCTITLE msg=audit(10/07/2026 00:37:30.013:3566) : proctitle=nano /etc/passwd
type=PATH msg=audit(10/07/2026 00:37:30.013:3566) : item=0 name=/etc/passwd inode=4719809 dev=08:01 mode=file,644 ouid=root ogid=root rdev=00:00 nametype=NORMAL cap_fp=none cap_fi=none cap_fe=0 cap_fver=0 cap_frootid=0
type=CWD msg=audit(10/07/2026 00:37:30.013:3566) : cwd=/media/sf_GRC102_W4_Evidence
type=SYSCALL msg=audit(10/07/2026 00:37:30.013:3566) : arch=x86_64 syscall=openat success=yes exit=3 a0=AT_FDCWD a1=0x5555a304d7a0 a2=0_RDONLY a3=0x0 item=1 ppid=32669 pid=32670 auid=kali uid=root gid=root euid=root suid=root fsuid=root egid=root sgid=root fsgid=root tty=pts1 ses=2 comm=nano exe=/usr/bin/nano subj=unconfined key=password_changes
type=PROCTITLE msg=audit(10/07/2026 00:37:30.013:3567) : proctitle=nano /etc/passwd
type=PATH msg=audit(10/07/2026 00:37:30.013:3567) : item=0 name=/etc/passwd inode=4719809 dev=08:01 mode=file,644 ouid=root ogid=root rdev=00:00 nametype=NORMAL cap_fp=none cap_fi=none cap_fe=0 cap_fver=0 cap_frootid=0
type=CWD msg=audit(10/07/2026 00:37:30.013:3567) : cwd=/media/sf_GRC102_W4_Evidence
type=SYSCALL msg=audit(10/07/2026 00:37:30.013:3567) : arch=x86_64 syscall=readlink success=no exit=EINVAL(Invalid argument) a0=0x7ffdf3ea800 a1=0x7ffdf3eb020 a2=0x3ff a3=0x5555a304dc5a items=1 ppid=32669 pid=32670 auid=kali uid=root gid=root euid=root suid=root fsuid=root egid=root sgid=root fsgid=root tty=pts1 ses=2 comm=nano exe=/usr/bin/nano subj=unconfined key=password_changes
(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$

```

Figure 10: ausearch -k passwd_changes limited to 00:37:29–00:37:31 (the nano session)

```

kali@kali: /media/sf_GRC102_W4_Evidence
Session Actions Edit View Help
(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$ sudo ausearch -k program_execution -i | tail -30 | tee 07_ausearch_exec.txt
type=PATH msg=audit(10/07/2026 00:40:45.985:5003) : item=2 name=/lib64/ld-linux-x86-64.so.2 inode=177057 dev=08:01 mode=file,755 ouid=root ogid=root rdev=00:00 nametype=NORMAL cap_fp=none cap_fi=none cap_fe=0 cap_fver=0 cap_frootid=0
type=PATH msg=audit(10/07/2026 00:40:45.985:5003) : item=1 name=/usr/bin/tee inode=4881678 dev=08:01 mode=file,755 ouid=root ogid=root rdev=00:00 nametype=NORMAL cap_fp=none cap_fi=none cap_fe=0 cap_fver=0 cap_frootid=0
type=PATH msg=audit(10/07/2026 00:40:45.985:5003) : item=0 name=/usr/bin/tee inode=4881678 dev=08:01 mode=file,755 ouid=root ogid=root rdev=00:00 nametype=NORMAL cap_fp=none cap_fi=none cap_fe=0 cap_fver=0 cap_frootid=0
type=CWD msg=audit(10/07/2026 00:40:45.985:5003) : cwd=/media/sf_GRC102_W4_Evidence
type=EXECVE msg=audit(10/07/2026 00:40:45.985:5003) : argc=2 a0=tee a1=07_ausearch_exec.txt
type=SYSCALL msg=audit(10/07/2026 00:40:45.985:5003) : arch=x86_64 syscall=execve success=yes exit=0 a0=0x7ffebfabc090 a1=0x7ffebfabc090 a2=0x556d2f14110 a3=0x8 items=3 ppid=1945 pid=35370 auid=kali uid=kali gid=kali euid=kali suid=kali fsuid=kali egid=kali sgid=kali fsgid=kali tty=pts0 ses=2 comm=tee exe=/usr/bin/tee subj=unconfined key=program_execution
type=PROCTITLE msg=audit(10/07/2026 00:40:45.985:5005) : proctitle=tail -30
type=PATH msg=audit(10/07/2026 00:40:45.985:5005) : item=2 name=/lib64/ld-linux-x86-64.so.2 inode=177057 dev=08:01 mode=file,755 ouid=root ogid=root rdev=00:00 nametype=NORMAL cap_fp=none cap_fi=none cap_fe=0 cap_fver=0 cap_frootid=0

```

Figure 11: ausearch -k program_execution (last 30 lines): commands recorded with arguments, user and terminal

```

kali@kali: /media/sf_GRC102_W4_Evidence
Session Actions Edit View Help
type=PROCTITLE msg=audit(10/07/2026 00:40:46.005:5022) : proctitle=ausearch -k program_execution -i
type=PATH msg=audit(10/07/2026 00:40:46.005:5022) : item=2 name=/lib64/ld-linux-x86-64.so.2 inode=177057 dev=08:01 mode=file,755 ouid=root ogid=root rdev=00:00 nametype=NORMAL cap_fp=none cap_fi=none cap_fe=0 cap_fver=0 cap_frootid=0
type=PATH msg=audit(10/07/2026 00:40:46.005:5022) : item=1 name=/usr/sbin/ausearch inode=4884738 dev=08:01 mode=file,755 ouid=root ogid=root rdev=00:00 nametype=NORMAL cap_fp=none cap_fi=none cap_fe=0 cap_fver=0 cap_frootid=0
type=PATH msg=audit(10/07/2026 00:40:46.005:5022) : item=0 name=/usr/sbin/ausearch inode=4884738 dev=08:01 mode=file,755 ouid=root ogid=root rdev=00:00 nametype=NORMAL cap_fp=none cap_fi=none cap_fe=0 cap_fver=0 cap_frootid=0
type=CWD msg=audit(10/07/2026 00:40:46.005:5022) : cwd=/media/sf_GRC102_W4_Evidence
type=EXECVE msg=audit(10/07/2026 00:40:46.005:5022) : argc=4 a0=ausearch a1=-k a2=program_execution a3=-i
type=SYSCALL msg=audit(10/07/2026 00:40:46.005:5022) : arch=x86_64 syscall=execve success=yes exit=0 a0=0x55bd3ebc8568 a1=0x55bd3ebc7450 a2=0x55bd3ebd27c0 a3=0x7f3322ab9778 items=3 ppid=35372 pid=35373 auid=kali uid=root gid=root euid=root suid=root fsuid=root egid=root sgid=root fsgid=root tty=pts1 ses=2 comm=ausearch exe=/usr/sbin/ausearch subj=unconfined key=program_execution
(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$ sudo ausearch -k auth_failures -i | tee 08_ausearch_auth.txt
<no matches>
(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$

```

Figure 12: ausearch -k auth_failures: <no matches> (no such rule exists on this host)

Item	Value
Total events	6,864
Commands recorded	108
Configuration changes	21
Logins / failed logins	0/0
Failed system calls	487 in the summary report, compared with 552 in the --failed report two minutes later
Anomaly events	1: ANOM_ABEND at 00:23:14 from systemd-sshd-generator
Audit keys in use	3

```
kali@kali: /media/sf_GRC102_W4_Evidence
Session Actions Edit View Help
(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$ sudo ausearch -k auth_failures -i | tee 08_ausearch_auth.txt
<no matches>
(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$ sudo aureport | tee 09_aureport_summary.txt

Summary Report
-----
Range of time in logs: 10/07/2026 00:23:14.702 - 10/07/2026 00:45:05.881
Selected time for report: 10/07/2026 00:23:14 - 10/07/2026 00:45:05.881
Number of changes in configuration: 21
Number of changes to accounts, groups, or roles: 0
Number of logins: 0
Number of failed logins: 0
Number of authentications: 0
Number of failed authentications: 0
Number of users: 3
Number of terminals: 7
Number of host names: 2
Number of executables: 49
Number of commands: 108
Number of files: 58
Number of AVC's: 0
Number of MAC events: 0
Number of failed syscalls: 487
Number of anomaly events: 1
Number of responses to anomaly events: 0
```

```
kali@kali: /media/sf_GRC102_W4_Evidence
Session Actions Edit View Help
Selected time for report: 10/07/2026 00:23:14 - 10/07/2026 00:45:05.881
Number of changes in configuration: 21
Number of changes to accounts, groups, or roles: 0
Number of logins: 0
Number of failed logins: 0
Number of authentications: 0
Number of failed authentications: 0
Number of users: 3
Number of terminals: 7
Number of host names: 2
Number of executables: 49
Number of commands: 108
Number of files: 58
Number of AVC's: 0
Number of MAC events: 0
Number of failed syscalls: 487
Number of anomaly events: 1
Number of responses to anomaly events: 0
Number of crypto events: 0
Number of integrity events: 0
Number of virt events: 0
Number of keys: 3
Number of process IDs: 5977
Number of events: 6864
(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$
```

Figure 13: aureport summary report

```
kali@kali: /media/sf_GRC102_W4_Evidence
Session Actions Edit View Help
Number of crypto events: 0
Number of integrity events: 0
Number of virt events: 0
Number of keys: 3
Number of process IDs: 5977
Number of events: 6864

(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$ sudo aureport --failed | tee 10_aureport_failed.txt

Failed Summary Report
Range of time in logs: 10/07/2026 00:23:14.702 - 10/07/2026 00:47:02.705
Selected time for report: 10/07/2026 00:23:14 - 10/07/2026 00:47:02.705
Number of changes in configuration: 0
Number of changes to accounts, groups, or roles: 0
Number of logins: 0
Number of failed logins: 0
Number of authentications: 0
Number of failed authentications: 0
Number of users: 1
Number of terminals: 2
Number of host names: 0
Number of executables: 10
Number of commands: 5
Number of files: 6
```

```
kali@kali: /media/sf_GRC102_W4_Evidence
Session Actions Edit View Help
Selected time for report: 10/07/2026 00:23:14 - 10/07/2026 00:47:02.705
Number of changes in configuration: 0
Number of changes to accounts, groups, or roles: 0
Number of logins: 0
Number of failed logins: 0
Number of authentications: 0
Number of failed authentications: 0
Number of users: 1
Number of terminals: 2
Number of host names: 0
Number of executables: 10
Number of commands: 5
Number of files: 6
Number of AVC's: 0
Number of MAC events: 0
Number of failed syscalls: 552
Number of anomaly events: 0
Number of responses to anomaly events: 0
Number of crypto events: 0
Number of integrity events: 0
Number of virt events: 0
Number of keys: 2
Number of process IDs: 111
Number of events: 552

(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$
```

Figure 14: aureport --failed

```
kali@kali: /media/sf_GRC102_W4_Evidence
Session Actions Edit View Help
Number of executables: 10
Number of commands: 5
Number of files: 6
Number of AVC's: 0
Number of MAC events: 0
Number of failed syscalls: 552
Number of anomaly events: 0
Number of responses to anomaly events: 0
Number of crypto events: 0
Number of integrity events: 0
Number of virt events: 0
Number of keys: 2
Number of process IDs: 111
Number of events: 552

(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$ sudo aureport --login | tee 11_aureport_login.txt

Login Report
# date time auid host term exe success event
<no events of interest were found>

(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$
```

Figure 15: aureport --login: no events of interest

Saved terminal output: 12_aureport_anomaly.txt

```
Anomaly Report
=====
# date time type exe term host auid event
=====
1. 10/07/2026 00:23:14 ANOM_ABEND /usr/lib/systemd/system-generators/systemd-sshd-generator ? ? unset 13
```

Figure 16: aureport --anomaly: ANOM_ABEND from systemd-sshd-generator

Interpretation. At 00:37:30, the user **kali** opened **/etc/passwd** in nano with root privileges. The file was opened in read-only mode, and there was no write access recorded during that period, so the account file was not changed.

From a governance perspective, this shows that privileged access to a sensitive file can be linked to a specific user, time, and terminal. However, there are two limitations. First, the rule uses **-p rwx**, so it records reads as well as writes and attribute changes. This can create a lot of routine events from sudo and system services, which could make actual changes harder to identify. In a production environment, I would use **-p wa** to focus on writes and attribute changes.

Second, the empty login report is expected because auditd was started after my session had already begun. As a result, there is no audit evidence for activity before **00:23:14**.

4.2 Module 2 – log management and analysis

Because **/var/log/auth.log** and **/var/log/syslog** do not exist on this Kali build, the systemd journal was used as the equivalent source for each check.

Saved terminal output: 13_journal_today.txt (last 16 lines shown, full file is in the evidence folder)

```
Oct 07 01:04:35 kali kernel: 05:04:35.158484 dnd No guest source window
Oct 07 01:04:35 kali kernel: 05:04:35.161900 dndHGCM DnD: Received message HOST_DND_FN_GH_REQ_PENDING (0x258) from host
Oct 07 01:04:35 kali kernel: 05:04:35.166804 dnd No guest source window
Oct 07 01:04:35 kali kernel: 05:04:35.170996 dndHGCM DnD: Received message HOST_DND_FN_GH_REQ_PENDING (0x258) from host
Oct 07 01:04:35 kali kernel: 05:04:35.176396 dnd No guest source window
Oct 07 01:04:35 kali kernel: 05:04:35.181621 dndHGCM DnD: Received message HOST_DND_FN_GH_REQ_PENDING (0x258) from host
Oct 07 01:04:35 kali kernel: 05:04:35.187372 dnd No guest source window
Oct 07 01:05:01 kali CRON[51287]: pam_unix(cron:session): session opened for user root(uid=0) by root(uid=0)
Oct 07 01:05:01 kali CRON[51289]: (root) CMD (command -v debian-sal1 > /dev/null && debian-sal1 1)
Oct 07 01:05:01 kali CRON[51287]: pam_unix(cron:session): session closed for user root
Oct 07 01:05:33 kali dbus-daemon[950]: [session uid=1000 pid=950 pidfd=5] Activating via systemd: service name='org.freedesktop.thumbnails.Thumbnailer1' unit='tumblerd.service' requested by ':1.29' (uid=1000 pid=1182 comm='Thunar --daemon' label='unconfined')
Oct 07 01:05:33 kali systemd[925]: Starting tumblerd.service - Thumbnailing service...
Oct 07 01:05:33 kali dbus-daemon[950]: [session uid=1000 pid=950 pidfd=5] Successfully activated service 'org.freedesktop.thumbnails.Thumbnailer1'
Oct 07 01:05:33 kali systemd[925]: Started tumblerd.service - Thumbnailing service.
Oct 07 01:07:08 kali sudo[53654]: kali: TTY=pts/0 ; PWD=/media/sf_GRC102_W4_Evidence ; USER=root ; COMMAND=/usr/bin/journalctl --since today --no-pager
Oct 07 01:07:08 kali sudo[53654]: pam_unix(sudo:session): session opened for user root(uid=0) by kali(uid=1000)
```

Figure 17: journalctl --since "today" (last 40 lines): cron job, thumbnail service, sudo entry, VirtualBox drag-and-drop messages

```
kali@kali: /media/sf_GRC102_W4_Evidence
Session Actions Edit View Help

(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$ sudo journalctl -p err --no-pager | tail -30 | tee 14_journal_errors.txt
Oct 06 11:49:45 kali kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* vmwgfx seems
to be running on an unsupported hypervisor.
Oct 06 11:49:45 kali kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* This configur
ation is likely broken.
Oct 06 11:49:45 kali kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* Please switch
to a supported graphics device to avoid problems.
Oct 06 11:50:24 kali lightdm[1064]: gkr-pam: unable to locate daemon control
file
Oct 06 11:50:35 kali obexd[2010]: Unable to acquire registry: Error calling S
tartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution
-source-registry.service not found.
Oct 06 11:50:35 kali obexd[2010]: Unable to acquire registry: Error calling S
tartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution
-source-registry.service not found.
-- Boot a2b72cd6cee14ba9af8b654c0f480455 --
Oct 06 23:36:34 kali kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* vmwgfx seems
to be running on an unsupported hypervisor.
Oct 06 23:36:34 kali kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* This configur
ation is likely broken.
Oct 06 23:36:34 kali kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* Please switch
to a supported graphics device to avoid problems.
Oct 06 23:37:17 kali lightdm[891]: gkr-pam: unable to locate daemon control f
ile
Oct 06 23:37:25 kali obexd[1808]: Unable to acquire registry: Error calling S
tartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution
```

```
kali@kali: /media/sf_GRC102_W4_Evidence
Session Actions Edit View Help

-source-registry.service not found.
Oct 06 23:37:25 kali obexd[1808]: Unable to acquire registry: Error calling S
tartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution
-source-registry.service not found.
Oct 06 23:56:38 kali xfce4-screensaver-dialog[14210]: pam_unix(xfce4-screensa
ver:auth): conversation failed
Oct 06 23:56:38 kali xfce4-screensaver-dialog[14210]: pam_unix(xfce4-screensa
ver:auth): auth could not identify password for [kali]
-- Boot b06aca15dd44c588df3520e58543975 --
Oct 07 00:00:46 kali kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* vmwgfx seems
to be running on an unsupported hypervisor.
Oct 07 00:00:46 kali kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* This configur
ation is likely broken.
Oct 07 00:00:46 kali kernel: vmwgfx 0000:00:02.0: [drm] *ERROR* Please switch
to a supported graphics device to avoid problems.
Oct 07 00:00:49 kali kernel: vboxsf: Unknown parameter 'tag'
Oct 07 00:01:08 kali lightdm[901]: gkr-pam: unable to locate daemon control f
ile
Oct 07 00:01:15 kali obexd[1822]: Unable to acquire registry: Error calling S
tartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution
-source-registry.service not found.
Oct 07 00:01:15 kali obexd[1822]: Unable to acquire registry: Error calling S
tartServiceByName for org.gnome.evolution.dataserver.Sources5: Unit evolution
-source-registry.service not found.
Oct 07 00:20:15 kali (generato[16221]): '/usr/lib/systemd/system-generators/sy
stemd-sshd-generator' terminated by signal SEGV.
Oct 07 00:23:14 kali (generato[20719]): '/usr/lib/systemd/system-generators/sy
stemd-sshd-generator' terminated by signal ABRT.
```

Figure 18: `journalctl -p err` (last 30 lines): graphics, keyring, sshd crash and screen-lock errors

Authentication and privilege use. The sudo logs recorded the user, terminal, working directory, target user, and exact command for each sudo command, including when the session started and ended. I found no **failed password** events in the journal. There were also no SSH service entries, which suggests that SSH was either not installed or had not been running.

Three authentication-related errors were linked to **xfce4-screensaver**, the screen-lock helper, rather than an actual login attempt. I could not confirm the cause of these errors, so I recorded them as errors of unconfirmed cause. Overall, I found no evidence of a hostile login attempt.

```
kali@kali: /media/sf_GRC102_W4_Evidence
Session Actions Edit View Help
-- No entries --
(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$
```

Figure 19: journalctl -u ssh: -- No entries --

```
kali@kali: /media/sf_GRC102_W4_Evidence
Session Actions Edit View Help
Oct 07 01:13:58 kali sudo[57888]:      kali : TTY=pts/0 ; PWD=/media/sf_GRC102_W4_Evidence ; USER=root ; COMMAND=
in/journalctl --no-pager
Oct 07 01:13:58 kali sudo[57888]: pam_unix(sudo:session): session opened for user root(uid=0) by kali(uid=1000)
Oct 07 01:13:58 kali sudo[57888]: pam_unix(sudo:session): session closed for user root
Oct 07 01:13:58 kali sudo[57895]:      kali : TTY=pts/0 ; PWD=/media/sf_GRC102_W4_Evidence ; USER=root ; COMMAND=
in/journalctl --no-pager
Oct 07 01:13:58 kali sudo[57895]: pam_unix(sudo:session): session opened for user root(uid=0) by kali(uid=1000)
Oct 07 01:13:58 kali sudo[57895]: pam_unix(sudo:session): session closed for user root
Oct 07 01:14:52 kali sudo[58428]:      kali : TTY=pts/0 ; PWD=/media/sf_GRC102_W4_Evidence ; USER=root ; COMMAND=
in/journalctl --no-pager
Oct 07 01:14:52 kali sudo[58428]: pam_unix(sudo:session): session opened for user root(uid=0) by kali(uid=1000)
Oct 07 01:14:52 kali sudo[58428]: pam_unix(sudo:session): session closed for user root
Oct 07 01:14:56 kali sudo[58533]:      kali : TTY=pts/0 ; PWD=/media/sf_GRC102_W4_Evidence ; USER=root ; COMMAND=
in/journalctl --no-pager
Oct 07 01:14:56 kali sudo[58533]: pam_unix(sudo:session): session opened for user root(uid=0) by kali(uid=1000)
Oct 07 01:14:56 kali sudo[58533]: pam_unix(sudo:session): session closed for user root
Oct 07 01:20:38 kali sudo[61365]:      kali : TTY=pts/0 ; PWD=/media/sf_GRC102_W4_Evidence ; USER=root ; COMMAND=
in/journalctl -u ssh --no-pager
Oct 07 01:20:38 kali sudo[61365]: pam_unix(sudo:session): session opened for user root(uid=0) by kali(uid=1000)
Oct 07 01:20:38 kali sudo[61365]: pam_unix(sudo:session): session closed for user root
Oct 07 01:21:06 kali sudo[61630]:      kali : TTY=pts/0 ; PWD=/media/sf_GRC102_W4_Evidence ; USER=root ; COMMAND=
in/journalctl -u ssh --no-pager
Oct 07 01:21:06 kali sudo[61630]: pam_unix(sudo:session): session opened for user root(uid=0) by kali(uid=1000)
Oct 07 01:21:06 kali sudo[61630]: pam_unix(sudo:session): session closed for user root
Oct 07 01:22:44 kali sudo[63508]:      kali : TTY=pts/0 ; PWD=/media/sf_GRC102_W4_Evidence ; USER=root ; COMMAND=
in/journalctl -t sudo --no-pager
Oct 07 01:22:44 kali sudo[63508]: pam_unix(sudo:session): session opened for user root(uid=0) by kali(uid=1000)
(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$ sudo journalctl --no-pager | grep -i ssh | tee 20_journal_ssh.txt
```

Figure 20: journalctl -t sudo (last 20 lines): privileged commands with user, terminal and time

```
Session Actions Edit View Help
(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$ [[200-clear
ssh: bad pattern: "[[200-clear
(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$ sudo journalctl --no-pager | grep -i "failed password" | tee 17_journal_failed_password.txt-
(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$
```

Figure 21: grep "failed password" over the journal: no output

```
Session Actions Edit View Help
Oct 06 23:56:38 kali xfce4-screensaver-dialog[14210]: pam_unix(xfce4-screensaver:auth): conversation failed
Oct 06 23:56:38 kali xfce4-screensaver-dialog[14210]: pam_unix(xfce4-screensaver:auth): auth could not identify
rd for [kali]
Oct 07 00:12:34 kali xfce4-screensaver-dialog[7530]: pam_unix(xfce4-screensaver:account): setuid failed: Operat
permitted
Oct 07 01:03:47 kali xfce4-screensaver-dialog[50676]: pam_unix(xfce4-screensaver:account): setuid failed: Oper
t permitted
(kali@kali)~/media/sf_GRC102_W4_evidence
$ clear
```

Figure 22: *pam_unix failure messages: screen-lock authentication errors*

Saved terminal output: 19_journal_warning_grep.txt

```
Oct 06 11:49:45 kali kernel: Warning! ehci_hcd should always be loaded before uhci_hcd and ohci_hcd, not
after
Oct 06 23:36:34 kali kernel: Warning! ehci_hcd should always be loaded before uhci_hcd and ohci_hcd, not
after
Oct 07 00:00:46 kali kernel: Warning! ehci_hcd should always be loaded before uhci_hcd and ohci_hcd, not
after
```

Figure 23: *grep "warning" over the journal (last 20 lines)*

The `ssllh` generator crashes. The journal shows that `systemd-ssllh-generator` terminated with SEGV at 00:20:15 and ABRT at 00:23:14. The second crash also appears in the audit anomaly record. The first happened about three minutes before `auditd` started, so it was only captured in the journal.

The `ssllh` package version 2.1.4 is installed, but `/etc/ssllh/` does not exist, so there was no configuration for the generator to process. I ran `systemctl daemon-reload`, after which the generator ran normally and the crash did not happen again. The exact cause could not be confirmed.

Saved terminal output: 20_journal_sslh.txt

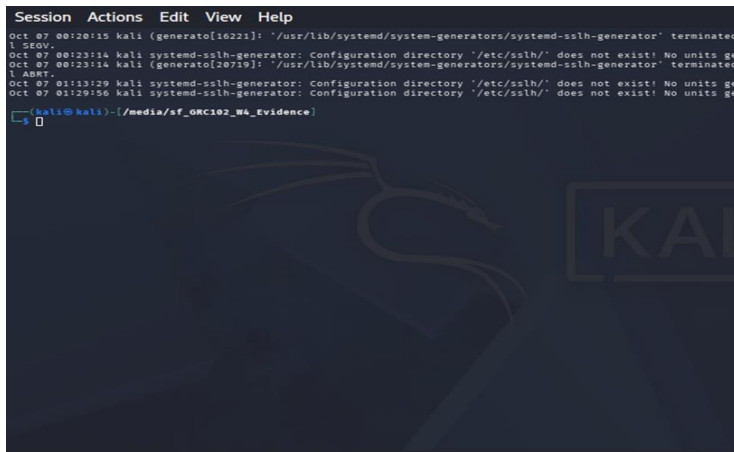
```
Oct 06 11:49:45 kali systemd-sslh-generator: Configuration directory '/etc/sslh/' does not exist! No units generated.
Oct 06 23:36:34 kali systemd-sslh-generator: Configuration directory '/etc/sslh/' does not exist! No units generated.
Oct 07 00:00:46 kali systemd-sslh-generator: Configuration directory '/etc/sslh/' does not exist! No units generated.
Oct 07 00:20:14 kali systemd-sslh-generator: Configuration directory '/etc/sslh/' does not exist! No units generated.
Oct 07 00:20:15 kali systemd-sslh-generator: Configuration directory '/etc/sslh/' does not exist! No units generated.
Oct 07 00:20:15 kali kernel: systemd-sslh-ge[16237]: segfault at 0 ip 00007fd00e0282d1 sp 00007ffcde14bfe8 error 6 in libc.so.6[1692d1,7fd00dee7000+16a000] likely on CPU 1 (core 1, socket 0)
Oct 07 00:20:15 kali (generato[16221]: '/usr/lib/systemd/system-generators/systemd-sslh-generator' terminated by signal SEGV.
Oct 07 00:23:14 kali systemd-sslh-generator: Configuration directory '/etc/sslh/' does not exist! No units generated.
Oct 07 00:23:14 kali (generato[20719]: '/usr/lib/systemd/system-generators/systemd-sslh-generator' terminated by signal ABRT.
```

Figure 24: journalctl output filtered for sslh: configuration message and two crashes

Saved terminal output: 21_sslh_package.txt

```
ii  sslh                                2.1.4-1+b1                                amd64
    Applicative protocol multiplexer
```

Figure 25: dpkg -l | grep sslh: package sslh 2.1.4-1+b1 installed



```
Session Actions Edit View Help
Oct 07 00:20:15 kali (generato[16221]: '/usr/lib/systemd/system-generators/systemd-sslh-generator' terminated
l SEGV.
Oct 07 00:23:14 kali systemd-sslh-generator: Configuration directory '/etc/sslh/' does not exist! No units ge
Oct 07 00:23:14 kali (generato[20719]: '/usr/lib/systemd/system-generators/systemd-sslh-generator' terminated
l ABRT.
Oct 07 01:13:29 kali systemd-sslh-generator: Configuration directory '/etc/sslh/' does not exist! No units ge
Oct 07 01:13:56 kali systemd-sslh-generator: Configuration directory '/etc/sslh/' does not exist! No units ge
kali@kali:~/media/sf_ORC102_Ma_Evidence
```

Figure 26: systemctl daemon-reload followed by sslh journal entries: no new crash

Event Table

Event/condition	Evidence source	Time	User/service	Security significance	Recommended action
Privileged commands through sudo	journalctl -t sudo	Oct 07 01:07:08 to 01:13:50	kali to root	Normal use, fully attributable. Privilege use is a core audit item	Keep sudo logging on; sample review of sudo logs
sslh generator crashed twice (SEGV, ABRT)	journalctl -p err; aureport --anomaly; dpkg -l	Oct 07 00:20:15 and 00:23:14	systemd / sslh 2.1.4	Unneeded package with an unconfirmed fault. The first crash has no audit record	Remove or configure sslh if not needed; monitor for repeats
Screen-lock authentication errors (3 entries)	journalctl, pam_unix	Oct 06 23:56:38; Oct 07 00:12:34 and 01:03:47	kali / xfce4-screensaver	Authentication-related, cause unconfirmed, no sign of a hostile attempt	Find the cause; alert if repeated
No failed-password events; SSH has no entries	journalctl -u ssh; grep	Whole journal	N/A	Low remote-login exposure. Absence of events is not proof of security	Keep SSH disabled unless needed; monitor if enabled
Scheduled root cron job (debian-sa1)	journalctl --since today	Oct 07 01:05:01	root / cron	Routine, expected scheduled task	None; watch for unexpected new jobs
High-volume VirtualBox drag-and-drop kernel messages	journalctl --since today	Oct 07 01:04:35	kernel (VirtualBox)	Benign, but noisy logs can hide real events	Filter in a SIEM; disable the feature if unused
Graphics and USB driver messages at each boot	journalctl -p err, grep	Each boot	kernel	VM configuration artefacts, no security impact	No action

4.3 Module 3 – Lynis Security Assessment

Lynis was not installed on the fresh Kali VM, so I installed version 3.1.6 from the Kali repository. The installation also created a `lynis.timer`. The apt output showed 1,452 packages not upgraded (Figures 30 and 29), which I recorded as a patch-management finding. I did not install the available upgrades because they were outside the scope of this lab.

```
Session Actions Edit View Help
Get:1 http://kali.download/kali kali-rolling/main amd64 lynis all 3.1.6-1 [276 kB]

Get:2 http://kali.download/kali kali-rolling/main amd64 menu amd64 2.1.51 [355 kB]

Fetched 631 kB in 11s (60.1 kB/s)
Selecting previously unselected package lynis.
(Reading database... 425881 files and directories currently installed.)
Preparing to unpack ../archives/lynis_3.1.6-1_all.deb...
Unpacking lynis (3.1.6-1)...
Selecting previously unselected package menu.
Preparing to unpack ../archives/menu_2.1.51_amd64.deb...
Unpacking menu (2.1.51)...
Setting up lynis (3.1.6-1)...
Created symlink '/etc/systemd/system/timers.target.wants/lynis.timer' -> '/usr/lib/
/systemd/lynis.timer'.
lynis.service is a disabled or a static unit, not starting it.
Setting up menu (2.1.51)...
Processing triggers for kali-menu (2026.2.6)...
Processing triggers for desktop-file-utils (0.28-1)...
Processing triggers for doc-base (0.11.2)...
Processing 43 changed doc-base files, 1 added doc-base file...
Processing triggers for man-db (2.13.1-1)...
Processing triggers for mailcap (3.76)...
Processing triggers for menu (2.1.51)...
sudo apt install lynis
(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$
```

Figure 27: apt installing Lynis 3.1.6 from the Kali repository (output tail)

Saved terminal output: 24_lynis_version.txt

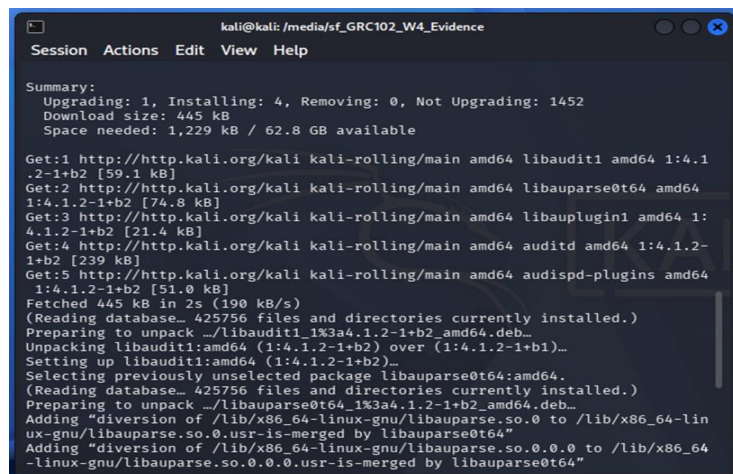
3.1.6

Figure 28: lynis show version

```
Session Actions Edit View Help
1453
(kali@kali)-[/media/sf_GRC102_W4_Evidence]
$
```

Figure 29: apt list --upgradable | wc -l result: 1453 lines, which is 1,452 packages plus one header line

The full audit ran 271 tests and returned a hardening index of 61, with 2 warnings and 49 suggestions. The two warnings, NETW-2704 and NETW-2705, reported that two responsive DNS servers were not found. This may be related to the VirtualBox network setup, but I did not verify the cause.

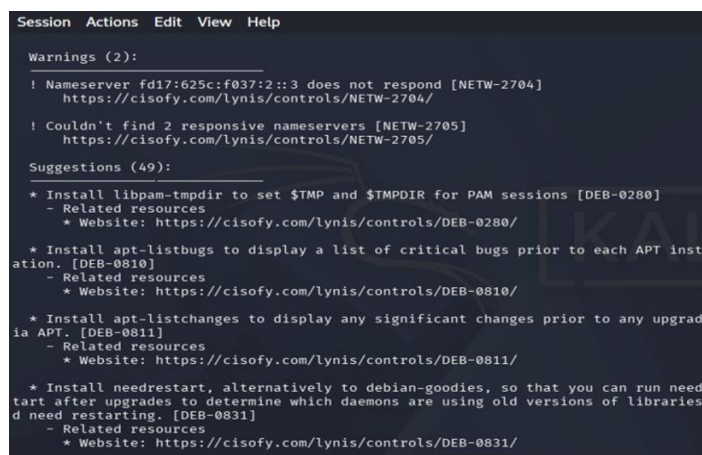


```
kali@kali: /media/sf_GRC102_W4_Evidence
Session Actions Edit View Help

Summary:
  Upgrading: 1, Installing: 4, Removing: 0, Not Upgrading: 1452
  Download size: 445 kB
  Space needed: 1,229 kB / 62.8 GB available

Get:1 http://http.kali.org/kali kali-rolling/main amd64 libaudit1 amd64 1:4.1
1.2-1+b2 [59.1 kB]
Get:2 http://http.kali.org/kali kali-rolling/main amd64 libauparse0t64 amd64
1:4.1.2-1+b2 [74.8 kB]
Get:3 http://http.kali.org/kali kali-rolling/main amd64 libauplugin1 amd64 1:
4.1.2-1+b2 [21.4 kB]
Get:4 http://http.kali.org/kali kali-rolling/main amd64 auditd amd64 1:4.1.2-
1+b2 [239 kB]
Get:5 http://http.kali.org/kali kali-rolling/main amd64 audispd-plugins amd64
1:4.1.2-1+b2 [51.0 kB]
Fetched 445 kB in 2s (190 kB/s)
(Reading database... 425756 files and directories currently installed.)
Preparing to unpack .../libaudit1_1%3a4.1.2-1+b2_amd64.deb...
Unpacking libaudit1:amd64 (1:4.1.2-1+b2) over (1:4.1.2-1+b1)...
Setting up libaudit1:amd64 (1:4.1.2-1+b2)...
Selecting previously unselected package libauparse0t64:amd64.
(Reading database... 425756 files and directories currently installed.)
Preparing to unpack .../libauparse0t64_1%3a4.1.2-1+b2_amd64.deb...
Adding 'diversion of /lib/x86_64-linux-gnu/libauparse.so.0 to /lib/x86_64-lin
ux-gnu/libauparse.so.0.usr-is-merged by libauparse0t64'
Adding 'diversion of /lib/x86_64-linux-gnu/libauparse.so.0.0.0 to /lib/x86_64
-linux-gnu/libauparse.so.0.0.0.usr-is-merged by libauparse0t64'
```

Figure 30: apt summary during the auditd install: “Not Upgrading: 1452”



```
Session Actions Edit View Help

Warnings (2):
! Nameserver fd17:625c:f037:2::3 does not respond [NETW-2704]
https://cisofy.com/lynis/controls/NETW-2704/
! Couldn't find 2 responsive nameservers [NETW-2705]
https://cisofy.com/lynis/controls/NETW-2705/

Suggestions (49):
* Install libpam-tmpdir to set $TMP and $TMPDIR for PAM sessions [DEB-0280]
- Related resources
* Website: https://cisofy.com/lynis/controls/DEB-0280/
* Install apt-listbugs to display a list of critical bugs prior to each APT inst
ation. [DEB-0810]
- Related resources
* Website: https://cisofy.com/lynis/controls/DEB-0810/
* Install apt-listchanges to display any significant changes prior to any upgrad
ia APT. [DEB-0811]
- Related resources
* Website: https://cisofy.com/lynis/controls/DEB-0811/
* Install needrestart, alternatively to debian-goodies, so that you can run need
tart after upgrades to determine which daemons are using old versions of libraries
d need restarting. [DEB-0831]
- Related resources
* Website: https://cisofy.com/lynis/controls/DEB-0831/
```

Figure 31: End of the Lynis scan: warnings and suggestions section

```
Session Actions Edit View Help

* Article: Linux hardening with sysctl settings: https://linux-audit.com/linux-hardening-with-sysctl/
* Article: Overview of sysctl options and values: https://linux-audit.com/kernel-sysctl/
* Website: https://cisofy.com/lynis/controls/KRM-6808/

* Harden compilers like restricting access to root user only [WDM-7222]
- Related Resources
  * Article: Why remove compilers from your system?: https://linux-audit.com/software/why-remove-compilers-from-your-system/
  * Website: https://cisofy.com/lynis/controls/WDM-7222/

* Harden the system by installing at least one malware scanner, to perform periodic file system scans [WDM-7238]
- Solution: Install a tool like rkhunter, chkrootkit, OSSEC, Wazuh
- Related Resources
  * Article: Antivirus for Linux: is it really needed?: https://linux-audit.com/malware/antivirus-for-linux-really-needed/
  * Article: Monitoring Linux Systems for Rootkits: https://linux-audit.com/monitoring-linux-systems-for-rootkits/
  * Website: https://cisofy.com/lynis/controls/WDM-7238/

Follow-up:
- Show details of a test (lynis show details TEST-ID)
- Check the logfile for all details (less /var/log/lynis.log)
- Read security controls tests (https://cisofy.com)
- Use --upload to upload data to central system (Lynis Enterprise users)

-----

Lynis security scan details:

Scan mode:
Normal ☒ Forensics ☐ Integration ☐ Pentest ☐

Lynis modules:
- Compliance status ☒
- Security audit ☒
- Vulnerability scan ☒

Details:
Hardening index - 61 [#####]
Tests performed - 271
Plugins enabled - 1

Software components:
- Firewall ☒
- Intrusion software ☒
- Malware scanner ☒

Files:
- Test and debug information : /var/log/lynis.log
```

Figure 32: End of the Lynis scan: hardening index and report/log file locations

Saved terminal output: 26_lynis_findings.txt

```
suggestion[]=DEB-0280|Install libpam-tmpdir to set $TMP and $TMPDIR for PAM sessions|-|-|
suggestion[]=DEB-0810|Install apt-listbugs to display a list of critical bugs prior to each APT installation.|-|-|
suggestion[]=DEB-0811|Install apt-listchanges to display any significant changes prior to any upgrade via APT.|-|-|
suggestion[]=DEB-0831|Install needrestart, alternatively to debian-goodies, so that you can run needrestart after
upgrades to determine which daemons are using old versions of libraries and need restarting.|-|-|
suggestion[]=DEB-0880|Install fail2ban to automatically ban hosts that commit multiple authentication errors.|-|-|
suggestion[]=BOOT-5122|Set a password on GRUB boot loader to prevent altering boot configuration (e.g. boot in
single user mode without password)|-|-|
suggestion[]=BOOT-5180|Determine runlevel and services at startup|-|-|
suggestion[]=BOOT-5264|Consider hardening system services|Run '/usr/bin/systemd-analyze security SERVICE' for each
service|-|-|
suggestion[]=AUTH-9230|Configure password hashing rounds in /etc/login.defs|-|-|
suggestion[]=AUTH-9262|Install a PAM module for password strength testing like pam_cracklib or pam_passwdqc or
libpam-passwdqc|-|-|
suggestion[]=AUTH-9282|When possible set expire dates for all password protected accounts|-|-|
suggestion[]=AUTH-9286|Configure minimum password age in /etc/login.defs|-|-|
suggestion[]=AUTH-9286|Configure maximum password age in /etc/login.defs|-|-|
suggestion[]=AUTH-9328|Default umask in /etc/login.defs could not be found and defaults usually to 022, which could
be more strict like 027|-|-|
suggestion[]=FILE-6310|To decrease the impact of a full /home file system, place /home on a separate partition|-|-|
suggestion[]=FILE-6310|To decrease the impact of a full /var file system, place /var on a separate partition|-|-|
suggestion[]=USB-1000|Disable drivers like USB storage when not used, to prevent unauthorized storage or data
theft|-|-|
suggestion[]=STRG-1846|Disable drivers like firewire storage when not used, to prevent unauthorized storage or data
theft|-|-|
suggestion[]=NAME-4028|Check DNS configuration for the dns domain name|-|-|
suggestion[]=PKGS-7308|Check RPM database as RPM binary available but does not reveal any packages|-|-|
suggestion[]=PKGS-7370|Install debsums utility for the verification of packages with known good database.|-|-|
suggestion[]=PKGS-7394|Install package apt-show-versions for patch management purposes|-|-|
suggestion[]=PKGS-7420|Consider using a tool to automatically apply upgrades|-|-|
suggestion[]=NETW-2704|Check connection to this nameserver and make sure no outbound DNS queries are blocked (port
53 UDP and TCP).|-|-|
warning[]=NETW-2704|Nameserver fd17:625c:f037:2::3 does not respond|-|-|
warning[]=NETW-2705|Couldn't find 2 responsive nameservers|-|-|
suggestion[]=NETW-2705|Check your resolv.conf file and fill in a backup nameserver if possible|-|-|
suggestion[]=NETW-3200|Determine if protocol 'dccp' is really needed on this system|-|-|
suggestion[]=NETW-3200|Determine if protocol 'sctp' is really needed on this system|-|-|
suggestion[]=NETW-3200|Determine if protocol 'rds' is really needed on this system|-|-|
suggestion[]=NETW-3200|Determine if protocol 'tipc' is really needed on this system|-|-|
suggestion[]=FIRE-4590|Configure a firewall/packet filter to filter incoming and outgoing traffic|-|-|
suggestion[]=HTTP-6640|Install Apache mod_evasive to guard webserver against DoS/brute force attempts|-|-|
suggestion[]=HTTP-6643|Install Apache mod_security to guard webserver against web application attacks|-|-|
suggestion[]=PHP-2376|Change the allow_url_fopen line to: allow_url_fopen = Off, to disable downloads via PHP|-|-|
suggestion[]=LOGG-2154|Enable logging to an external logging host for archiving purposes and additional protection|-|-|
suggestion[]=LOGG-2190|Check what deleted files are still in use and why.|-|-|
suggestion[]=INSE-8300|Remove rsh client when it is not in use or replace with the more secure SSH package|-|-|
suggestion[]=INSE-8318|It is recommended that TFTP be removed, unless there is a specific need for TFTP (such as a
boot server)|-|-|
suggestion[]=INSE-8320|Removing the atftpd package decreases the risk of the accidental (or intentional) activation
of tftp services|-|-|
suggestion[]=BANN-7126|Add a legal banner to /etc/issue, to warn unauthorized users|-|-|
suggestion[]=BANN-7130|Add legal banner to /etc/issue.net, to warn unauthorized users|-|-|
suggestion[]=ACCT-9622|Enable process accounting|-|-|
suggestion[]=ACCT-9626|Enable sysstat to collect accounting (disabled)|-|-|
suggestion[]=FINT-4350|Install a file integrity tool to monitor changes to critical and sensitive files|-|-|
suggestion[]=TOOL-5002|Determine if automation tools are present for system management|-|-|
suggestion[]=FILE-7524|Consider restricting file permissions|See screen output or log file|text:Use chmod to change
file permissions|
suggestion[]=HOME-9304|Double check the permissions of home directories as some might be not strict enough.|-|-|
suggestion[]=KRNL-6000|One or more sysctl values differ from the scan profile and could be tweaked|Change sysctl
value or disable test (skip-test=KRNL-6000:<sysctl-key>)|
suggestion[]=HRDN-7222|Harden compilers like restricting access to root user only|-|-|
suggestion[]=HRDN-7230|Harden the system by installing at least one malware scanner, to perform periodic file system
scans|-|Install a tool like rkhunter, chkrootkit, OSSEC, Wazuh|
hardening index=61
```

Figure 33: Warnings, suggestions and hardening_index pulled from /var/log/lynis-report.dat

Saved terminal output: 26b_lynis_suggestion_count.txt and 26c_lynis_warning_count.txt

```
suggestions: 49
warnings: 2
```

Figure 34: sudo grep -c counts: 49 suggestions, 2 warnings

Prioritised findings

Risk/control issue	Evidence	Likely owner	Recommended remediation	Priority
Patch backlog: unpatched software is a leading route for compromise	apt: Not Upgrading 1452; PKGS-7420 (no automatic upgrade tool)	IT Operations / system administrator	Snapshot, run a full upgrade, enable automatic security updates	High
No host firewall: traffic is not filtered	FIRE-4590; Firewall [X] in the scan summary	Network / infrastructure security	Enable a host firewall with default-deny inbound	High
No external log host: logs can be lost or altered with the host	LOGG-2154; audit and journal logs kept only locally	Security Operations / SIEM owner	Forward audit and journal logs to a central collector	Medium
No file-integrity or malware tooling	FINT-4350; HRDN-7230	Security Operations	Deploy a file-integrity tool and baseline critical files	Medium
Weak password policy settings	AUTH-9286, AUTH-9262, AUTH-9282	Identity and access management	Set password ageing; add a password-strength PAM module	Medium
No legal login banner	BANN-7126, BANN-7130 (BANN-7126 remediated, see 4.4)	Compliance with system administrator	Keep banner text approved by Legal	Low

Kali is designed for penetration testing, so some Lynis findings, such as compilers, TFTP and rsh clients, and PHP settings, may be present by design. This means the hardening results should be considered against the actual role of the system rather than treated as requirements for every Linux host.

Lynis also reported that its version was more than six months old. This means some newer checks may not be included, and a newer release may be available from the official source. I did not verify this.

4.4 Optional Hardening and Retest: Login Banner (BANN-7126)

- **Control objective:** Display a warning to unauthorised users and support access control enforcement.
- **Change made:** I added two warning lines to `/etc/issue` and kept the original file as `/etc/issue.bak`.
- **Operational impact:** None. The change only affects the text displayed at the console login prompt.
- **Verification:** I compared the `/etc/issue` output before and after the change and ran a targeted Lynis check for BANN-7126. The result changed from a suggestion to OK.

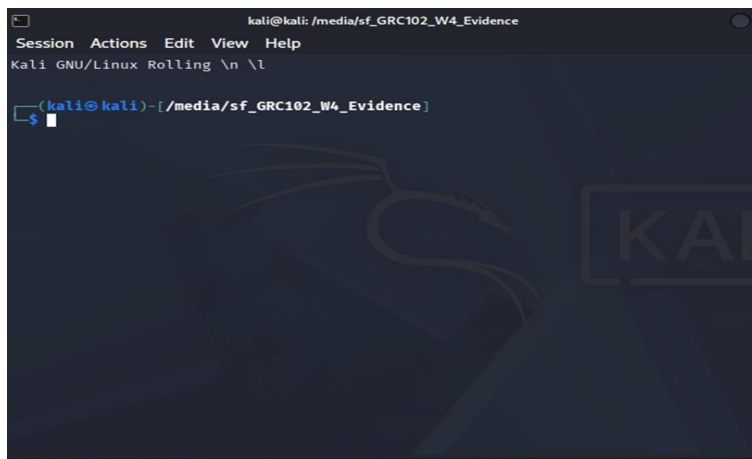


Figure 35: *cat /etc/issue before the change*

Saved terminal output: 28_issue_after.txt

```
Kali GNU/Linux Rolling \n \l

Unauthorized access to this system is prohibited.
Authorized use only. Activity may be monitored and recorded.
```

Figure 36: *cat /etc/issue after the change: warning lines added*

Saved terminal output: 29_lynis_retest.txt (Banners section only)

```
[+] Banners and identification
-----
- /etc/issue contents [ OK ]
```

Figure 37: *Lynis retest, "Banners and identification" section: /etc/issue contents [OK]*

Saved terminal output: 29_lynis_retest.txt (results block only)

```
-[ Lynis 3.1.6 Results ]-
Great, no warnings
No suggestions

=====
Lynis security scan details:
Scan mode:
Normal [■] Forensics [ ] Integration [ ] Pentest [ ]
Lynis modules:
- Compliance status [?]
- Security audit [V]
- Vulnerability scan [V]
Details:
Hardening index : 100 [#####]
Tests performed : 1
Plugins enabled : 1
Software components:
- Firewall [X]
- Intrusion software [X]
- Malware scanner [X]
```

Figure 38: *Lynis retest results block: no warnings, no suggestions (single test)*

Note on the score. The retest shows a hardening index of 100, but that run performed only one test ("Tests performed: 1", against 271 in the full audit). It is not comparable with the full audit result of 61 and I do not claim an overall improvement from it.

5. Control-Monitoring Table

Thresholds are example values I proposed for this exercise. A real organisation would set its own.

Control/objective	Evidence	Owner	Observed status	KPI / KRI or threshold	Risk / significance	Remediation	Retest / follow-up
Privileged access accountability: every elevation traceable to a person	journalctl -t sudo (user, terminal, folder, time); audit record of sudo nano /etc/passwd with auid=kali	IAM / Security Operations	Effective	% of sudo events tied to a named user (target 100%). Escalate any elevation by an unrecognised account	Privilege use is a core audit item; here it is attributable and timestamped	Keep sudo logging on; review samples	Monthly sample review of sudo logs
Sensitive file monitoring (/etc/passwd, /etc/shadow)	auditctl -l; ausearch -k passwd_changes (read-only open, no write)	Security Operations	Operating, but noisy	Any unauthorised write to a watched file = immediate escalation; events per day as a noise measure	Broad -p rwx rule records every read and can bury real changes	Tune to -p wa so only writes and attribute changes are logged	Controlled test write in a lab; confirm one clear record
Audit coverage and log retention	auditd absent by default; aureport -login empty; first ssh crash (00:20:15) in the journal only; Lynis LOGG-2154	Security Operations / SIEM owner	Partially effective	% of hosts with auditd active and forwarding logs (target 100%); any host below target goes to the Risk function	Events before auditd started have no audit evidence; local-only logs can be lost or altered	Include auditd in the baseline build; forward logs to a central collector	Quarterly coverage check
Patch management	apt: 1,452 packages not upgraded; Lynis PKGS-7420; Lynis itself reported as outdated	IT Operations / system administrator	Not effective (backlog)	Days since last update; % of critical patches applied within SLA (e.g. 14 days). Escalate when SLA is exceeded	Unpatched software is a leading route for compromise	Snapshot, full upgrade, enable automatic security updates	apt list --upgradable after the upgrade; recheck monthly

Host firewall / network protection	Lynis FIRE-4590; Firewall [X] in the scan summary	Network / infrastructure security	Not met	Hosts without an active host firewall (target 0)	Inbound and outbound traffic is unfiltered	Enable a default-deny inbound host firewall	Re-run Lynis and check the firewall item
Component stability / unnecessary software	aureport -- anomaly (ANOM_ABEND 00:23:14); journal: sslh generator SEGV and ABRT; dpkg -l: sslh installed, no /etc/sslh/; daemon-reload did not reproduce	System administrator / configuration management	Partially effective (intermittent, cause unconfirmed)	Abnormal-exit events per host per week; escalate repeats of the same component	Unneeded software adds attack surface and maintenance load	Remove or configure sslh if not needed; monitor	Check journal and aureport -- anomaly after one week
Authentication monitoring and login warning banner	No failed-password events; SSH has no entries; 3 PAM errors from the screen-lock helper; BANN-7126 moved from suggestion to OK	IAM / Compliance with system administrator	Banner remediated; no significant authentication events observed	Failed logins per account per 10 minutes (e.g. 5 = alert); lockout patterns to Security Operations	Absence of events is not proof of security; the banner supports enforcement	Maintain the banner; investigate the screen-lock errors if they repeat	Repeat the Lynis banner test after any change to /etc/issue

6. SIEM and Continuous Monitoring Mapping

This section is conceptual. No SIEM was deployed and no logs were forwarded in this lab, so the mapping describes how the evidence could be used. The tools named are examples.

Evidence source	What it contains	How it reaches a SIEM	Parsing / normalisation	Detection or alert rule	Output
auditd (/var/log/audit/audit.log)	Watched-file access, program execution, anomaly events, with auid, uid, terminal and time	Collection agent (for example Wazuh or Elastic Agent), or auditd's dispatcher plugins (audispd-plugins was installed)	Key=value fields mapped to user, process, file and action; the key label used as a tag	Write to /etc/passwd or /etc/shadow; repeated ANOM_ABEND on one host	Technical alert; governance issue if unauthorised or repeated
systemd journal	sudo use, PAM messages, service crashes, kernel errors	Journal forwarding to syslog (rsyslog) or a collection agent	Parsed by program tag (sudo, pam_unix, systemd) into user, command and result	Authentication-failure bursts; sudo by an unexpected account; repeated service crashes	Technical alert; trend report to Security Operations
Authentication events (PAM and failed-password searches)	Login successes and failures	Same journal pipeline; SSH logs too if SSH is enabled	Normalised into a login-event category by account and source	Several failures per account in a short window (example: 5 in 10 minutes)	Alert; to the CISO if a success follows the failures
Lynis (/var/log/lynis-report.dat)	Hardening index, warnings and suggestions with test IDs	Scheduled scan (the package enabled lynis.timer); report file collected by the agent or a script	Test IDs (for example FIRE-4590) mapped to controls and severity	Index below a baseline; new warnings; critical items open past a deadline	Dashboard and tickets for governance
Package state (apt list --upgradable)	Pending updates	Scheduled script sending a count to the SIEM or a vulnerability tool	Count per host	Pending backlog above the SLA	Governance issue, owned by IT Operations

Flow: host evidence (auditd, journal, Lynis) → collection agent → SIEM (normalise, correlate, alert) → dashboards, tickets and reports → control owners, then the Risk function and the CISO.

What stays a technical alert and what becomes a governance issue

Stays a technical operational alert	Becomes a governance / control-assurance issue
A single failed login	Failed authentication that repeats across systems, or is followed by a successful login
One service crash (the sslh case)	The same component failing repeatedly, or on many hosts
Routine noise (VirtualBox messages, cron jobs)	Log volume so high that it hides real events, which means rules need tuning
One sudo command by a known administrator	Elevation by an unknown account, or outside change windows
One pending update	A patch backlog above the SLA (1,452 pending packages here)
One Lynis suggestion	A control failing across several hosts, a falling hardening index, or a finding open past its deadline
An audit rule firing on a lab test	A host with no audit coverage, because missing evidence is itself a control failure

7. Governance Discussion and Escalation Questions

The audit evidence could be forwarded to a SIEM, where keys such as `passwd_changes` can be used to detect activity on sensitive files. Journal entries from `sudo`, `PAM`, and system services could also be collected centrally to give Security Operations one timeline of privileged and authentication activity. Lynis could be run regularly, with the hardening index and warning count tracked over time.

A single failed login, crash, or normal `sudo` command would normally remain a technical alert for Security Operations. It becomes a governance concern when it points to a control weakness, such as missing audit coverage, logs being stored only locally, a patch backlog that has passed its agreed deadline, or the same fault continuing to occur.

1. Which finding is the highest priority?

The patch backlog is the highest priority because it can affect the overall security of the host and can be measured and remediated. I did not check how many of the 1,452 pending updates are security updates, so I have described them as **pending updates** rather than security updates. The missing firewall is the next priority.

2. Who should own remediation?

IT Operations should own patching, while Network or Infrastructure Security should handle the firewall. Security Operations or the SIEM owner should be responsible for audit and log coverage, file integrity, and malware monitoring. IAM should own the password policy. Compliance and the system administrator can handle the login banner and package clean-up, with Legal approving the banner wording.

3. What should trigger escalation?

Any unauthorised write to `/etc/passwd` or `/etc/shadow` should be escalated directly to the CISO. A host without audit coverage or a critical patch that has passed its deadline should be escalated to the Risk function. A repeated issue across several hosts, or a finding that remains open beyond its deadline, should be escalated to the management committee.

4. What evidence shows successful remediation?

Remediation should be supported by before-and-after evidence. This could include `apt list --upgradable` showing that the backlog has been cleared, an active firewall shown by `ufw status` or `nft list ruleset` together with a clean Lynis firewall check, evidence that logs are reaching the central collector, and the **BANN-7126** retest that has already been collected.

5. When and how should the control be retested?

After each fix, I would rerun the relevant Lynis audit and `ausearch` and `aureport` checks. These checks should then be repeated on a schedule, such as monthly for patching and quarterly for audit coverage, with each result compared against the previous one.

8. Remediation and Retest Plan

Timeframes are my proposals, not organisational standards.

Action	Owner	Priority	Proposed timeframe	Evidence of closure	Retest
Apply pending updates; enable automatic security updates	IT Operations	High	14 days	apt list --upgradable shows no backlog	Monthly
Enable a default-deny inbound host firewall	Network / infrastructure security	High	7 days	Firewall status output; Lynis FIRE-4590 clear	Re-run Lynis after change
Forward audit and journal logs to a central collector	Security Operations / SIEM owner	Medium	60 days	Test events visible in the collector	Quarterly
Deploy a file-integrity tool; baseline critical files	Security Operations	Medium	60 days	Tool reports a baseline and alerts on a test change	Quarterly
Set password ageing and add a password-strength module	IAM	Medium	30 days	login.defs and PAM settings; Lynis AUTH items clear	Re-run Lynis
Tune the /etc/passwd watch rule to -p wa	Security Operations	Medium	30 days	Test write gives one clear record; reads no longer logged	After rule change
Remove or configure ssh if not required	System administrator	Low	30 days	dpkg -l no longer lists it, or a valid /etc/ssh/ exists	One week after; check journal and aureport --anomaly

9. Conclusion

The host records privileged activity and access to sensitive files effectively, and I was able to trace the recorded events to a user, terminal, and time. However, the overall protection and coverage still have some gaps, including the large patch backlog, lack of a host firewall, local-only log storage, and the gap in audit coverage before auditd was started.

The retest also showed that a small, low-risk control can be fixed and verified quickly. The main limitations of this assessment are that it covered only one host during one lab session, the Lynis version was more than six months old, some issues such as the `ss1h` crashes and screen-lock errors had unconfirmed causes, and no SIEM was available for central log collection.

Based on the evidence collected, the recommendations in this report represent the order in which I would address the identified issues.